МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РФ
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ БЮДЖЕТНОЕ
ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»
(ФГБОУ ВО «ВГТУ», ВГТУ)
Факультет информационных технологий и компьютерной безопасности
Кафедра систем информационной безопасности

ОТЧЁТ
по научно-исследовательской работе студента

Тема: «Разработка интеллектуальной системы оценки и регулирования киберрисков инфраструктуры контейнеризации Kubernetes при компрометации контейнерных приложений»

Разработал студент
гр. КБ-211 «_____» К.Ю.Полыга
Подпись, дата Инициалы, фамилия

Руководитель: «_____»
Подпись, дата, должность, инициалы, фамилия

Защищен_____ Оценка_____
дата

Воронеж 2026

СОДЕРЖАНИЕ

ВВЕДЕНИЕ 3
1 Исследование аналогов и постановка задач работы в области проактивного управления рисками нарушения информационной безопасности инфраструктуры контейнеризации Kubernetes при компрометации контейнерных приложений 12
1.1 Анализ особенностей инфраструктуры контейнеризации как объекта защиты корпоративной автоматизированной системы 12
1.2 Исследование статистики и тенденций инцидентов безопасности в контейнерных средах 16
1.3 Анализ нормативного обеспечения и профилей безопасности NIST SP 800-190 и CIS Kubernetes Benchmark 18
1.4 Сравнительный анализ средств контроля защищённости кластера Kubernetes 21
1.5 Исследование риск-калькуляторов CVSS 3.1, CVSS 4.0, EPSS и факторной модели FAIR 23
1.6 Выявление противоречий и постановка задач работы 26
СПИСОК ЛИТЕРАТУРЫ 31

ВВЕДЕНИЕ

Переход корпоративных информационных систем к микросервисной архитектуре привёл к тому, что основной средой исполнения прикладного программного обеспечения стала инфраструктура контейнеризации, а система оркестрации Kubernetes – фактическим стандартом управления такой средой [1]. Кластер объединяет в едином контуре плоскость управления, вычислительные узлы, рабочие нагрузки и реестр образов контейнеров, каждый из которых обладает собственной границей доверия и собственным набором полномочий. Тем самым кластер определяет, какое приложение, к каким ресурсам инфраструктуры и в каком объёме прав допущено, а следовательно, задаёт границы того ущерба, который может быть нанесён организации при переходе контейнерного приложения под контроль нарушителя. Особенность рассматриваемого объекта состоит в том, что компрометация единственной рабочей нагрузки ею не ограничивается: избыточные полномочия сервисного аккаунта, примонтированный каталог узла или доступный сокет среды исполнения контейнеров превращают прикладной инцидент в компрометацию узла, а затем и плоскости управления, обесценивая прочие применённые средства защиты информации.

Распространённость рассматриваемого объекта защиты и характер наступающих в нём инцидентов подтверждаются данными зарубежных отраслевых исследований. По результатам ежегодного опроса State of Kubernetes Security Report доля организаций, отметивших не менее одного инцидента безопасности контейнерной среды в течение предшествовавших двенадцати месяцев, составила 93 % в 2022 году, 90 % в 2023 году, 89 % в 2024 году и 86 % в 2025 году, причём преобладающей причиной инцидента на всём протяжении наблюдения остаётся не уязвимость образа, а недостаток конфигурации: его доля изменялась в пределах от 45 до 53 % при доле инцидентов, вызванных уязвимостью программного обеспечения, от 27 до 33 % [2]. По данным исследования Cloud-Native Security and Usage Report доля учётных записей и сервисных аккаунтов кластеров, которым предоставлены полномочия, фактически не используемые рабочей нагрузкой, возросла с 84 % в 2022 году до 98 % в 2025 году, а доля рабочих нагрузок,

исполняемых с правами суперпользователя, составила порядка трети от общего их числа [3]. Согласно ежегодному исследованию Cloud Native Computing Foundation, оркестрация контейнерных приложений применяется в промышленной эксплуатации в 66 % организаций при общем уровне применения технологии 84–96 %, что определяет масштаб распространения объекта защиты [4]. Отчёт Data Breach Investigations Report фиксирует устойчивый рост доли инцидентов, в которых начальным вектором выступила эксплуатация уязвимости или недостатка конфигурации внешнего сервиса, с 14 % в 2023 году до 20 % в 2025 году [5].

Аналогичная тенденция наблюдается и в отечественной практике. По данным экспертно-аналитического центра InfoWatch число зарегистрированных утечек информации из российских организаций составило порядка 660 в 2023 году и превысило 1000 в 2024 году, при этом доля инцидентов, в которых нарушителем использовались штатные средства администрирования и предоставленные полномочия, а не вредоносное программное обеспечение, устойчиво возрастает [6]. Аналитические отчёты об актуальных киберугрозах показывают, что доля успешных атак на организации, приведших к нарушению основной деятельности, в 2024–2025 годах превысила треть от общего их числа, а среди применяемых нарушителем техник преобладают получение и использование действительных учётных данных и эксплуатация недостатков конфигурации внешних сервисов [7]. В банке данных угроз безопасности информации ФСТЭК России по состоянию на начало 2026 года зарегистрировано 222 угрозы безопасности информации, из которых к средам виртуализации и контейнеризации применимы 24 угрозы, включая угрозы выхода за пределы виртуальной машины, нарушения изоляции пользовательских данных и несанкционированного доступа к гипервизору и средствам управления средой виртуализации [8].

Приведённые данные свидетельствуют о смене характера атаки на контейнерную инфраструктуру: нарушитель всё чаще не эксплуатирует программный дефект в образе, а использует штатно предоставленные рабочей нагрузке полномочия и допущенные при развёртывании ослабления изоляции. Сведения, необходимые для риск-анализа такой инфраструктуры, накоплены в

развитой системе источников: международных реестрах CVE и NVD [9-10], банке данных угроз безопасности информации ФСТЭК России [8], средствах количественной оценки критичности – векторе CVSS версий 3.1 и 4.0 [11-12] и прогнозе вероятности эксплуатации EPSS [13], – а также в профильных руководствах по защите контейнерных сред. Вместе с тем эти сведения распределены между источниками, различающимися предметом описания и формой представления, и для проактивного риск-анализа кластера – оценки риска до реализации атаки, по состоянию его конфигурации – должны быть сведены в единую структуру, связывающую привилегированный режим пода, монтирование узловых каталогов, избыточные привязки ролей механизма RBAC и иные недостатки конфигурации с техниками их эксплуатации и наступающим ущербом.

Существующие средства анализа защищённости контейнерных сред – Kubescape и kube-bench [14-15], Trivy и Falco [16-17] – выполняют проверку объектов кластера на соответствие профилю безопасности, обнаруживают уязвимости образов и фиксируют аномальное поведение среды исполнения. Результат их работы выражается оценкой соответствия профилю и перечнем находок с качественной градацией критичности. Для управления риском такой результат является исходным материалом: чтобы обосновать выбор мер защиты и оценить их эффективность, выявленные недостатки требуется перевести в количественную меру риска с учётом их сочетаемости в цепочке «выход за границы контейнера – компрометация узла – доступ к плоскости управления», рассчитать первичный риск до внедрения мер и остаточный риск после их внедрения. Именно такой замкнутый цикл – от идентификации сценария атаки через расчёт первичного риска и выбор мер защиты к расчёту остаточного риска и количественной верификации решения – составляет содержание проактивного подхода к управлению рисками нарушения информационной безопасности [18-19].

Степень проработанности темы. Вопросы риск-анализа в области защиты информации получили развитие в трудах отечественной научной школы, в которых разработаны методики оценки рисков успешности реализации кибератак, построения риск-ландшафтов сетевых атак и организационно-правового

обеспечения противодействия им [20-22]. Требования к защите информации в информационных системах установлены нормативными документами ФСТЭК России [23-25] и национальными стандартами [26-28]. Особенности обеспечения безопасности приложений, исполняемых в контейнерной среде, изложены в руководстве NIST SP 800-190 и наборе проверок CIS Kubernetes Benchmark [29-30], а техники, применяемые нарушителем в инфраструктуре контейнеризации, систематизированы в матрице MITRE ATT&CK for Containers [31]. Количественный подход к анализу информационного риска развит в факторной модели FAIR [18], а экономическое обоснование мер защиты – в показателе возврата инвестиций в безопасность ROSI [32]. Представление путей нарушителя в инфраструктуре графом достижимых состояний и анализ таких графов, в том числе с вероятностной оценкой успешности переходов, развиты в работах по автоматизированному построению графов атак [33-35], что создаёт основу для перехода от оценки отдельного недостатка к оценке сценария компрометации. Вместе с тем в известных работах объектом риск-анализа выступают программное обеспечение и информационная система в целом, тогда как применительно к инфраструктуре контейнеризации требуется сопряжение перечисленных подходов в едином цикле проактивного управления риском, единицей анализа в котором выступает рабочая нагрузка кластера, что и определяет горизонты настоящего исследования.

Актуальность темы исследования обусловлена наличием противоречий между:

- существующим информационным обеспечением проектной деятельности по управлению рисками инфраструктуры контейнеризации Kubernetes и необходимостью его совершенствования в части покрытия потребностей проактивного риск-анализа инфраструктуры контейнеризации Kubernetes при компрометации контейнерных приложений;

- существующими методиками риск-анализа инфраструктуры контейнеризации Kubernetes и необходимостью их совершенствования в части учёта проактивных принципов оценки риска нарушения ИБ при компрометации контейнерных приложений с использованием методов машинного обучения;

- существующими методиками управления рисками нарушения ИБ инфраструктуры контейнеризации Kubernetes и необходимостью их совершенствования в части проактивного регулирования риска на основе результатов машинного обучения;

- имеющимися средствами автоматизации оценки и регулирования рисков инфраструктуры контейнеризации Kubernetes и необходимостью их совершенствования для оценки эффективности предлагаемых технических решений в части проактивного экспресс-анализа процессов управления риском.

Объектом исследования является инфраструктура контейнеризации Kubernetes автоматизированной информационной системы организации, включающая плоскость управления, вычислительные узлы, рабочие нагрузки и реестр образов контейнеров.

Предметом исследования являются информационное, аналитическое и программное обеспечение проактивной оценки и регулирования рисков нарушения информационной безопасности инфраструктуры контейнеризации Kubernetes при компрометации контейнерных приложений.

Целью исследования является повышение защищённости автоматизированных информационных систем за счёт разработки интеллектуальной системы оценки и регулирования киберрисков инфраструктуры контейнеризации Kubernetes в условиях компрометации контейнерных приложений.

Для достижения поставленной цели необходимо решить следующие задачи:

- создание информационного обеспечения, покрывающего потребности проектной деятельности по проактивному управлению рисками нарушения ИБ инфраструктуры контейнеризации Kubernetes при компрометации контейнерных приложений;

- создание аналитики проактивного риск-анализа нарушений ИБ инфраструктуры контейнеризации Kubernetes, учитывающей специфику недостатков конфигурации кластера и сценариев компрометации контейнерных приложений и возможности предиктивных моделей машинного обучения;

- создание аналитики проактивного управления рисками нарушений ИБ инфраструктуры контейнеризации Kubernetes, учитывающей результаты оценки первичного риска и специфику недостатков конфигурации кластера и сценариев компрометации контейнерных приложений;

- формирование средств автоматизации, заточенных под проактивный экспресс-анализ процессов оценки и регулирования рисков нарушения ИБ инфраструктуры контейнеризации Kubernetes, а также оценка эффективности предлагаемых мер защиты.

Методы исследования. При решении поставленных задач применяются методы системного анализа и декомпозиции сложных систем, аппарат теории рисков и факторная модель анализа информационного риска FAIR, методы теории вероятностей и математической статистики, теория графов при формировании сценариев компрометации кластера, методы машинного обучения при оценке уровня риска рабочих нагрузок, методы экономической оценки эффективности мер защиты, а также методы объектно-ориентированного программирования при разработке программного обеспечения интеллектуальной системы.

Решение поставленных задач позволяет получить следующие результаты, выносимые на защиту:

- необходимое и достаточное для решения задач работы информационное обеспечение проактивного риск-анализа инфраструктуры контейнеризации Kubernetes при компрометации контейнерных приложений;

- аналитическое обеспечение проактивной оценки риска нарушения ИБ инфраструктуры контейнеризации Kubernetes при компрометации контейнерных приложений;

- аналитическое обеспечение проактивной регулировки риска нарушения ИБ инфраструктуры контейнеризации Kubernetes при компрометации контейнерных приложений;

- средства автоматизации предложенных методик оценки и регулирования риска нарушения ИБ инфраструктуры контейнеризации Kubernetes, а также оценка эффективности разработанных мер защиты для кластера Kubernetes.

Новизна полученных результатов заключается в следующем:

- предлагаемое информационное обеспечение, в отличие от аналогов, формализует описание активов кластера и границ доверия между ними, сценариев компрометации контейнерных приложений и источников данных в едином составе, ориентированном на проактивный риск-анализ;

- разработанная аналитика риск-анализа нарушений ИБ инфраструктуры контейнеризации Kubernetes, в отличие от аналогов, учитывает результаты предиктивной модели машинного обучения для оценки уровня риска рабочей нагрузки по параметрам манифеста при расчёте первичного риска на основе факторной модели FAIR;

- разработанная аналитика управления ИБ-рисками на объекте, в отличие от аналогов, предусматривает автоматизированный выбор мер защиты с учётом их масштабности и профильности и расчёт остаточного риска с последующей количественной верификацией;

- созданные средства автоматизации проектной ИБ-деятельности на объекте, в отличие от аналогов, позволяют в автоматическом режиме выполнять полный цикл проактивного управления риском – от идентификации сценария атаки до количественной верификации эффективности выбранных мер.

Практическая ценность полученных результатов состоит в следующем:

- структура и состав предложенного информационного обеспечения ИБ-деятельности на объекте могут быть практически использованы при построении систем проактивного управления рисками инфраструктуры контейнеризации Kubernetes;

- на практике предложенные методики риск-анализа позволяют получать количественную оценку первичного риска нарушения ИБ инфраструктуры контейнеризации Kubernetes до реализации сценария компрометации;

- практическое применение предложенной аналитики управления ИБ-рисками видится в поддержке принятия решений по выбору мер защиты инфраструктуры контейнеризации Kubernetes с учётом их экономической эффективности;

- созданные средства автоматизации проектной ИБ-деятельности на объекте практически необходимы для внедрения проактивного подхода к управлению рисками инфраструктуры контейнеризации Kubernetes.

Теоретическая значимость результатов исследования определяется следующим образом:

- методики сбора и обработки данных, предложенные в работе, могут быть развиты применительно к иным платформам оркестрации контейнеров и видам недостатков конфигурации;

- разработанные методики риск-анализа целесообразно развить в части учёта иных классов угроз и мультикластерных и гибридных сред;

- перспективное развитие предложенной аналитики управления ИБ-рисками видится в расширении состава учитываемых мер защиты и сценариев компрометации кластера;

- теоретическая значимость созданного инструментария видится в возможности его адаптации для иных платформ оркестрации контейнеров и классов угроз.

Информационную базу исследования составляют нормативные правовые акты и методические документы ФСТЭК России, национальные стандарты в области защиты информации и менеджмента риска, руководство NIST SP 800-190, набор проверок CIS Kubernetes Benchmark и стандарты безопасности рабочих нагрузок Kubernetes, матрица MITRE ATT&CK for Containers, международные реестры и базы данных уязвимостей, спецификации систем CVSS и EPSS, открытый стандарт факторного анализа информационного риска, ежегодные отраслевые отчёты о безопасности контейнерных сред, а также публикации отечественной научной школы в области риск-анализа и регулирования рисков кибератак.

Апробация результатов. Результаты исследования планируются к докладу на научно-практических конференциях и семинарах, проводимых кафедрой систем информационной безопасности, а также к обсуждению в рамках научно-исследовательской работы обучающихся.

Публикация результатов. Результаты исследования планируются к опубликованию в научном журнале «Информация и безопасность», а также в сборниках трудов научно-практических конференций по направлению обеспечения информационной безопасности.

Настоящая работа выполнена в объёме научно-исследовательской работы и содержит введение, первую главу выпускной квалификационной работы и список литературы. В первой главе исследуются особенности инфраструктуры контейнеризации Kubernetes как объекта защиты, статистика и тенденции инцидентов безопасности в контейнерных средах, нормативное обеспечение и профили безопасности, существующие средства контроля защищённости кластера и риск-калькуляторы, выявляются противоречия и ставятся задачи работы. Решение поставленных задач составляет содержание второй – пятой глав выпускной квалификационной работы: вторая глава посвящена созданию информационного обеспечения проактивного риск-анализа, третья – аналитическому обеспечению проактивной оценки рисков, четвёртая – аналитическому обеспечению проактивного регулирования рисков, пятая – автоматизации предложенных методик и обоснованию эффективности мер защиты. Такое построение воспроизводит последовательность проактивного управления риском: информационное обеспечение задаёт множество учитываемых недостатков конфигурации и сценариев их эксплуатации, аналитическое обеспечение оценки переводит их в первичный риск, аналитическое обеспечение регулирования – в выбор мер защиты и остаточный риск, а средства автоматизации обеспечивают выполнение этой последовательности при каждом изменении конфигурации кластера и количественную верификацию принятых решений.

1 Исследование аналогов и постановка задач работы в области проактивного управления рисками нарушения информационной безопасности инфраструктуры контейнеризации Kubernetes при компрометации контейнерных приложений

Настоящая глава посвящена исследованию аналогов и обоснованию целеполагания работы. В соответствии с методическими рекомендациями по выполнению работ в области обеспечения информационной безопасности [20] её назначение состоит в подробном обосновании противоречий, положенных в основу исследования, и в постановке задач, решение каждой из которых составляет содержание последующих глав. Исследование опирается на терминологию, принятую в отечественной научной школе [26], согласно которой безопасность есть состояние защищённости от внешних и внутренних угроз, при котором риск реализации этих угроз не превышает допустимых значений; угроза – совокупность факторов, воздействие которых способно привести к ущербу; ущерб – совокупность негативных последствий реализации угроз; риск – возможность наступления ущерба от реализации угроз, а мера риска определяется произведением величины ожидаемого ущерба на вероятность его наступления.

Изложение строится в следующем порядке: рассматриваются особенности инфраструктуры контейнеризации как объекта защиты, статистика и тенденции инцидентов безопасности в контейнерных средах, нормативное обеспечение и профили безопасности, существующие средства контроля защищённости кластера и риск-калькуляторы, после чего выявляются противоречия и формулируются задачи работы.

1.1 Анализ особенностей инфраструктуры контейнеризации как объекта защиты корпоративной автоматизированной системы

Контейнеризация представляет собой разновидность виртуализации на уровне операционной системы, при которой прикладное программное обеспечение вместе с необходимыми ему библиотеками и зависимостями упаковывается в образ и исполняется изолированно от прочих приложений, но в среде общего ядра

операционной системы узла. Изоляция обеспечивается механизмами ядра – пространствами имён, разграничивающими видимость процессов, сетевых интерфейсов, точек монтирования и идентификаторов пользователей, и контрольными группами, ограничивающими потребление вычислительных ресурсов. Принципиальное отличие контейнеризации от виртуализации на основе гипервизора состоит в том, что контейнеры не располагают собственным ядром: граница изоляции между контейнером и узлом реализуется программно, средствами того же ядра, которое обслуживает все исполняемые на узле рабочие нагрузки. Вследствие этого ослабление параметров изоляции, допущенное при развёртывании, переводит инцидент прикладного уровня в инцидент уровня инфраструктуры, что и определяет специфику рассматриваемого объекта защиты [36].

Жизненный цикл контейнерного приложения включает сборку образа, его размещение в реестре образов, получение образа узлом и запуск контейнера средой исполнения. Каждый из перечисленных этапов образует самостоятельную точку приложения усилий нарушителя: образ может содержать внесённый в него посторонний код, реестр – выдать подменённый образ, среда исполнения – запустить контейнер с избыточными полномочиями. Тем самым защищённость исполняемого приложения определяется не только его собственным кодом, но и параметрами всей цепочки, по которой это приложение оказалось на узле.

По мере роста числа контейнерных приложений их ручное размещение становится неосуществимым, вследствие чего применяются системы оркестрации, принимающие на себя планирование размещения рабочих нагрузок по узлам, их масштабирование, организацию сетевого взаимодействия, предоставление хранилищ и управление конфиденциальными параметрами. Kubernetes является де-факто стандартом оркестрации контейнерных приложений [1] и применяется как в собственных центрах обработки данных организаций, так и в облачных средах. Существенно, что система оркестрации не только управляет рабочими нагрузками, но и сама выступает носителем полномочий: она располагает учётными данными для обращения к реестру образов, хранит конфиденциальные параметры приложений и обладает возможностью запуска произвольной рабочей нагрузки на

любом подчинённом узле. Компрометация системы оркестрации, таким образом, эквивалентна компрометации всех обслуживаемых ею приложений и данных.

Кластер Kubernetes образован двумя группами компонентов. Плоскость управления включает сервер программных интерфейсов kube-apiserver, являющийся единственной точкой обращения к кластеру и выполняющий аутентификацию, авторизацию и допуск запросов; распределённое хранилище etcd [37], содержащее полное состояние кластера, включая конфиденциальные параметры приложений; планировщик kube-scheduler, определяющий узел размещения рабочей нагрузки; и менеджер контроллеров kube-controller-manager, приводящий фактическое состояние кластера к заданному. Вычислительные узлы включают агент kubelet, управляющий жизненным циклом контейнеров на узле и обращающийся к серверу программных интерфейсов; сетевой агент kube-proxy; и среду исполнения контейнеров [38], непосредственно взаимодействующую с ядром операционной системы узла.

Рабочие нагрузки представлены подами – минимальными планируемыми единицами, объединяющими один или несколько контейнеров с общими пространствами имён. Каждому поду сопоставляется сервисный аккаунт, от имени которого выполняются обращения к серверу программных интерфейсов; объём предоставленных сервисному аккаунту прав определяется механизмом управления доступом на основе ролей [39]. Реестр образов, располагающийся вне кластера либо в его составе, хранит образы, из которых создаются контейнеры, и является точкой, определяющей доверие к исполняемому коду.

Перечисленные компоненты не равнозначны с точки зрения защиты информации: они располагают различным объёмом полномочий, обслуживают различные множества субъектов и влекут различный ущерб при компрометации. Соответствующее сопоставление приведено в таблице 1.

Таблица 1 – Компоненты кластера Kubernetes и последствия их компрометации

Компонент кластера	Назначение и располагаемые полномочия	Последствия компрометации
Сервер программных интерфейсов	Единственная точка обращения к кластеру; выполняет аутентификацию, авторизацию и допуск запросов	Полное управление кластером, запуск произвольных рабочих нагрузок на любом узле
Хранилище etcd	Хранит полное состояние кластера, включая конфиденциальные параметры приложений	Утрата конфиденциальности всех секретов кластера, возможность подмены его состояния
Планировщик и менеджер контроллеров	Определяют размещение рабочих нагрузок и приводят состояние кластера к заданному	Управление размещением нагрузок, размещение посторонней нагрузки на выбранном узле
Агент узла kubelet	Управляет жизненным циклом контейнеров на узле, обращается к серверу программных интерфейсов	Управление всеми контейнерами узла, доступ к их конфиденциальным параметрам
Среда исполнения контейнеров	Создаёт и исполняет контейнеры, взаимодействует с ядром операционной системы узла	Получение прав на узле, выход за границы изоляции контейнера
Рабочая нагрузка (под)	Исполняет прикладной код, располагает правами сопоставленного сервисного аккаунта	Исходная точка цепочки компрометации инфраструктуры
Реестр образов	Хранит образы, из которых создаются контейнеры	Внесение постороннего кода во все создаваемые из образа контейнеры

Между перечисленными компонентами устанавливаются границы доверия – условные рубежи, пересечение которых нарушителем означает расширение множества доступных ему активов и, как следствие, возрастание величины наступающего ущерба. В рассматриваемом объекте защиты выделяются четыре такие границы: между контейнером и узлом, на котором он исполняется; между узлом и плоскостью управления кластера; между пространствами имён, разграничивающими рабочие нагрузки различных подразделений или систем; между кластером и внешним реестром образов.

Из рассмотренных особенностей следует положение, определяющее подход настоящей работы к объекту защиты. Величина ущерба от компрометации отдельной рабочей нагрузки определяется не свойствами самой нагрузки, а множеством активов, достижимых при её использовании: две рабочие нагрузки, исполняющие идентичный прикладной код, влекут различный ущерб, если одна из них исполняется в привилегированном режиме с примонтированным каталогом

узла, а вторая – с минимальным набором полномочий. Состояние же конфигурации, определяющее такую достижимость, известно заранее – из манифестов развёртывания, привязок ролей и параметров компонентов кластера – и может быть проанализировано до того, как нарушитель им воспользуется. Это обстоятельство делает инфраструктуру контейнеризации естественным объектом проактивного риск-анализа, при котором оценка риска выполняется по состоянию конфигурации, а не по факту зарегистрированного инцидента.

1.2 Исследование статистики и тенденций инцидентов безопасности в контейнерных средах

Количественные характеристики инцидентов безопасности контейнерных сред приводятся в ежегодных отраслевых исследованиях, выполняемых по опросам эксплуатирующих организаций и по данным систем мониторинга. Сводные показатели за четыре года наблюдения приведены в таблице 2.

Таблица 2 – Динамика показателей безопасности контейнерных сред по данным зарубежных отраслевых исследований

Показатель	2022	2023	2024	2025	Источник
Доля организаций, отметивших не менее одного инцидента безопасности контейнерной среды за 12 месяцев, %	93	90	89	86	[2]
Доля инцидентов, вызванных недостатком конфигурации, %	53	45	46	48	[2]
Доля инцидентов, вызванных уязвимостью образа, %	27	33	32	30	[2]
Доля организаций, задержавших развёртывание приложений из-за выявленных проблем безопасности, %	55	67	42	46	[2]
Доля предоставленных, но не используемых полномочий сервисных аккаунтов, %	84	90	98	98	[3]
Доля организаций, применяющих оркестрацию в промышленной эксплуатации, %	60	63	66	66	[4]

Приведённые в таблице 2 данные обнаруживают три устойчивые тенденции. Во-первых, доля организаций, столкнувшихся с инцидентом безопасности контейнерной среды, на всём интервале наблюдения превышает четыре пятых, то есть инцидент в такой среде является не исключительным, а ожидаемым событием. Во-вторых, недостаток конфигурации устойчиво преобладает над уязвимостью образа в качестве причины инцидента, и соотношение между ними не изменяется в пользу уязвимостей при том, что средства выявления уязвимостей образов получили за рассматриваемый период наибольшее распространение. В-третьих, доля предоставленных, но не используемых полномочий сервисных аккаунтов приближается к предельной, что означает систематическое превышение фактически необходимого объёма прав рабочих нагрузок и, как следствие, систематическое завышение величины ущерба, наступающего при компрометации отдельного контейнерного приложения.

Преобладание недостатков конфигурации подтверждается и эмпирическими исследованиями манифестов рабочих нагрузок, размещённых в открытых репозиториях: привилегированный режим, монтирование каталогов узла, отсутствие ограничений ресурсов и иные ослабления изоляции встречаются в значительной доле развёртываний и воспроизводятся при копировании типовых шаблонов [40]. Тем самым недостаток конфигурации распространяется не как единичная ошибка администратора, а как тиражируемое свойство практики развёртывания.

Отечественная статистика подтверждает установленные тенденции применительно к российским организациям. Согласно данным экспертно-аналитического центра InfoWatch, число зарегистрированных утечек информации выросло с порядка 660 в 2023 году до величины, превышающей 1000 в 2024 году, при сохранении высокой доли инцидентов, в которых нарушитель действовал от имени легитимной учётной записи [6]. Аналитические отчёты об актуальных киберугрозах фиксируют, что более трети успешных атак на организации в 2024–2025 годах привели к нарушению основной деятельности, а в числе преобладающих техник указываются использование действительных учётных данных и эксплуатация недостатков конфигурации доступных из внешних сетей сервисов [7].

В банке данных угроз безопасности информации ФСТЭК России зарегистрировано 222 угрозы, из которых к средам виртуализации и контейнеризации применимы 24, в том числе угрозы выхода за пределы виртуальной машины, нарушения изоляции пользовательских данных и несанкционированного доступа к средствам управления средой виртуализации [8]. Перечисленные угрозы сформулированы для технологии виртуализации в целом, и их применение к кластеру Kubernetes предполагает соотнесение объектов воздействия с компонентами системы оркестрации.

Приведённые данные позволяют заключить, что преобладающей причиной инцидентов в контейнерных средах выступает не дефект программного кода в образе приложения, а состояние конфигурации самой инфраструктуры – избыточные полномочия рабочих нагрузок, ослабленные параметры изоляции и недостаточное разграничение доступа к плоскости управления. Поскольку такое состояние наблюдаемо до реализации атаки, статистика инцидентов обосновывает переход от реагирования на уже состоявшиеся события к проактивной оценке риска по состоянию конфигурации кластера.

1.3 Анализ нормативного обеспечения и профилей безопасности NIST SP 800-190 и CIS Kubernetes Benchmark

Требования к защите информации, обрабатываемой в автоматизированных информационных системах, частью которых выступает инфраструктура контейнеризации, установлены нормативными правовыми актами и методическими документами ФСТЭК России, а также национальными стандартами. Приказ ФСТЭК России № 17 определяет состав мер защиты информации в государственных информационных системах, приказ № 21 – в информационных системах персональных данных, приказ № 239 – на значимых объектах критической информационной инфраструктуры [23-25]. Порядок определения угроз безопасности информации установлен методическим документом «Методика оценки угроз безопасности информации» [41], в соответствии с которым угроза описывается совокупностью нарушителя, способа реализации, объекта воздействия и наступающих последствий.

Особенности защиты информации при использовании технологий виртуализации установлены ГОСТ Р 56938 [42], который вводит перечень мер защиты, применяемых к средствам виртуализации, включая разграничение доступа к средствам управления виртуальной инфраструктурой, контроль целостности образов, регистрацию событий безопасности и изоляцию вычислительных ресурсов. Классификация и правила описания уязвимостей информационных систем установлены ГОСТ Р 56545 и ГОСТ Р 56546 [27-28], причём последний относит к самостоятельному классу уязвимости конфигурации, возникающие в результате задания параметров программного обеспечения, обеспечивающих возможность реализации угроз. Общие положения менеджмента риска установлены ГОСТ Р ИСО/МЭК 27005, ГОСТ Р ИСО 31000 и ГОСТ Р 58771 [19, 43-44], определяющими риск через сочетание вероятности события и его последствий, вводящими понятия обработки риска и остаточного риска и устанавливающими перечень применимых технологий оценки риска.

Перечисленные документы формулируют требования к защите информации в терминах мер защиты. Их реализация в инфраструктуре контейнеризации выполняется посредством конкретных параметров конфигурации кластера; соответствие между требуемыми мерами защиты и такими параметрами приведено в таблице 3.

Таблица 3 – Соответствие мер защиты информации и параметров конфигурации кластера

Мера защиты информации и её источник	Параметр конфигурации кластера, реализующий меру	Последствие неприменения меры
Идентификация и аутентификация субъектов доступа (приказ ФСТЭК России № 17, ИАФ) [23]	Запрет анонимных обращений к серверу программных интерфейсов и к агенту узла kubelet	Доступ к объектам кластера без прохождения аутентификации
Управление доступом субъектов к объектам (приказ ФСТЭК России № 17, УПД) [23]	Привязки ролей механизма RBAC, ограниченные необходимым объёмом полномочий	Обращение рабочей нагрузки к объектам кластера за пределами прикладной задачи
Регистрация событий безопасности (приказ ФСТЭК России № 17, РСБ) [23]	Политика журналирования обращений к серверу программных интерфейсов, ретенция журналов	Невозможность установления обстоятельств инцидента

Продолжение таблицы 3

Мера защиты информации и её источник	Параметр конфигурации кластера, реализующий меру	Последствие неприменения меры
Защита среды виртуализации (ГОСТ Р 56938) [42]	Запрет привилегированного режима пода, монтирования каталогов узла и пространств имён узла	Переход нарушителя с уровня контейнера на уровень узла
Обеспечение целостности информационной системы (приказ ФСТЭК России № 17, ОЦЛ) [23]	Проверка подписи образа, перечень допустимых реестров, неизменяемые идентификаторы содержимого	Исполнение постороннего кода, внесённого в образ контейнера
Защита информации при её передаче (ГОСТ Р 56938) [42]	Взаимная аутентификация компонентов плоскости управления, шифрование хранимых секретов	Раскрытие конфиденциальных параметров кластера
Управление конфигурацией информационной системы (приказ ФСТЭК России № 17, УКФ) [23]	Политики допуска рабочих нагрузок, контроль изменений манифестов развёртывания	Развёртывание рабочей нагрузки с параметрами, не отвечающими требованиям защиты

Приведённое соответствие показывает, что всякая мера защиты информации, установленная нормативными документами применительно к инфраструктуре контейнеризации, реализуется значением одного или нескольких параметров конфигурации кластера, а неприменение меры выражается в состоянии этих параметров.

Детализацию нормативных требований применительно к контейнерной среде дают профили безопасности. Руководство NIST SP 800-190 по безопасности контейнерных приложений систематизирует риски контейнерной среды по пяти группам, соответствующим элементам её жизненного цикла: риски образов, риски реестров, риски систем оркестрации, риски контейнеров и риски операционной системы узла [29]. Для каждой группы приводятся характерные недостатки и рекомендуемые контрмеры; риски при этом описываются качественно – через перечень нежелательных обстоятельств и их последствий.

Набор проверок CIS Kubernetes Benchmark представляет собой перечень контролируемых параметров кластера, сгруппированных по компонентам плоскости управления, хранилищу etcd, вычислительным узлам и политикам [30]. Каждая проверка имеет собственный идентификатор, формулируется как требование к значению параметра и сопровождается порядком его установления и исправления.

Сходные по составу перечни контролируемых параметров приводятся в наборе проверок среды исполнения контейнеров [45], в руководстве по усилению защищённости кластера [46], в перечне наиболее значимых рисков инфраструктуры Kubernetes [47] и в стандартах безопасности рабочих нагрузок, разделяющих допустимые параметры подов на базовый и ограничительный профили [48]; применение профилей к создаваемым рабочим нагрузкам обеспечивается контроллерами допуска [49]. Результатом применения набора проверок является оценка соответствия параметра требованию.

Тем самым нормативные документы и профили безопасности определяют полное множество контролируемых параметров кластера и требуемых мер защиты. Для проактивного риск-анализа они служат источником перечня недостатков конфигурации, подлежащих учёту, тогда как количественное сопоставление рабочих нагрузок между собой по величине риска и выбор мер по критерию его снижения составляют предмет самостоятельной разработки.

1.4 Сравнительный анализ средств контроля защищённости кластера Kubernetes

Практическая оценка защищённости контейнерных сред выполняется специализированными средствами, реализующими проверку объектов кластера на соответствие профилю безопасности, анализ состава образов и контроль поведения среды исполнения [14-17]. Результаты сравнительного анализа наиболее распространённых средств приведены в таблице 4.

Таблица 4 – Сравнительный анализ средств контроля защищённости кластера Kubernetes

Средство	Назначение	Форма представления результата
kube-bench	Проверка параметров компонентов кластера на соответствие набору CIS Kubernetes Benchmark	Перечень проверок с отметками «пройдена», «не пройдена», «требует ручной проверки»
Kubescape	Проверка объектов кластера и манифестов по нескольким профилям с сопоставлением контролей техникам MITRE ATT&CK	Перечень несоответствий с уровнями критичности, процентная оценка соответствия профилю

Продолжение таблицы 4

Средство	Назначение	Форма представления результата
Trivy	Выявление уязвимостей образов по реестрам уязвимостей и ошибок конфигурации в манифестах рабочих нагрузок	Перечень находок с качественной градацией критичности, оценка CVSS для уязвимостей
Falco	Обнаружение аномального поведения среды исполнения по правилам на основе системных вызовов	Поток событий с уровнями приоритета

Средство kube-bench реализует проверки набора CIS Kubernetes Benchmark для компонентов плоскости управления и вычислительных узлов и выдаёт перечень проверок с отметкой результата. Средство Kubescape проверяет объекты кластера и манифесты рабочих нагрузок по нескольким профилям – в том числе руководству по усилению защищённости кластера и набору проверок CIS – и сопоставляет контроли с техниками матрицы MITRE ATT&CK, представляя результат перечнем несоответствий с уровнями критичности и процентной оценкой соответствия профилю. Средство Trivy выявляет уязвимости образов по реестрам уязвимостей, сопровождая их оценкой CVSS, а также ошибки конфигурации в манифестах. Средство Falco анализирует системные вызовы и события среды исполнения и формирует поток событий с уровнями приоритета.

Выполненный анализ позволяет установить общие свойства рассмотренных средств. Во-первых, результат их работы выражается оценкой соответствия профилю и перечнем находок с качественной градацией критичности, тогда как для управления риском требуется мера риска, определяемая произведением ущерба на вероятность его наступления и допускающая сравнение состояний кластера до и после внедрения мер защиты. Во-вторых, основной единицей результата выступает отдельная проверка или отдельное событие, а совокупное влияние сочетания недостатков на достижимость активов кластера – например, привилегированного режима пода вместе с избыточной привязкой роли его сервисного аккаунта – требует дополнительного анализа. В-третьих, выбор мер защиты по результатам проверок выполняется по перечню несоответствий, а обоснование этого выбора величиной снижения риска и его экономической целесообразностью в функции средств не входит.

Таким образом, рассмотренные средства выступают источником первичных данных о состоянии конфигурации кластера и могут быть использованы на входе проактивного риск-анализа, а его аналитическое обеспечение – расчёт первичного и остаточного риска и верификация мер защиты – подлежит разработке.

1.5 Исследование риск-калькуляторов CVSS 3.1, CVSS 4.0, EPSS и факторной модели FAIR

Количественная оценка критичности уязвимостей в практике защиты информации выполняется риск-калькуляторами, среди которых наибольшее распространение получили система оценки критичности уязвимостей CVSS и система прогнозирования вероятности эксплуатации EPSS. Международный реестр CVE [9] присваивает уникальные идентификаторы общеизвестным уязвимостям, национальная база данных уязвимостей NVD [10] дополняет записи реестра вектором и базовой оценкой CVSS, а банк данных угроз безопасности информации ФСТЭК России содержит сведения об уязвимостях программного обеспечения и перечень угроз, соотнесённых с объектами воздействия и последствиями их реализации [8]. Типы недостатков программного обеспечения, лежащие в основе уязвимостей, систематизированы в перечне CWE [50].

Система CVSS версии 3.1 выражает критичность уязвимости числом от 0 до 10, вычисляемым по трём группам метрик: базовым, описывающим свойства самой уязвимости – вектор атаки, сложность, требуемые привилегии, участие пользователя, область воздействия и влияние на конфиденциальность, целостность и доступность; временным, учитывающим зрелость эксплойта и наличие исправления; средовым, позволяющим уточнить оценку с учётом требований к безопасности конкретной системы [11]. Версия 4.0 перестраивает состав метрик: наряду с базовыми вводятся метрики угрозы, средовые метрики, раздельно учитывающие воздействие на уязвимую и на последующие системы, и дополнительные метрики, характеризующие, в частности, автоматизируемость атаки и возможность восстановления [12]. Раздельный учёт воздействия на уязвимый компонент и на последующие системы существенен для инфраструктуры контейнеризации, в

которой последствия компрометации рабочей нагрузки распространяются за её пределы – на узел и плоскость управления.

Система EPSS оценивает вероятность того, что уязвимость реестра CVE будет эксплуатироваться в течение ближайших тридцати дней, и строит эту оценку по наблюдаемым признакам эксплуатационной активности и характеристикам уязвимости [13]. Тем самым EPSS дополняет CVSS вероятностной составляющей: если CVSS отвечает на вопрос о тяжести последствий, то EPSS – о правдоподобии эксплуатации.

Обе системы оценивают отдельную уязвимость. Для риск-анализа инфраструктуры контейнеризации их метрики представляют ценность как признаки, из которых складываются вероятность и ущерб: вектор атаки, требуемые привилегии и область воздействия характеризуют условия успешной компрометации рабочей нагрузки, а средовые метрики – значимость затрагиваемых активов. Перенос этих метрик на недостатки конфигурации кластера и сценарии их эксплуатации позволяет использовать накопленную методическую базу риск-калькуляторов при оценке объекта, описываемого не только уязвимостями, но и состоянием конфигурации.

Переход от оценки критичности к оценке риска в денежном или вероятностном выражении обеспечивает факторная модель анализа информационного риска FAIR [18], принятая в качестве открытого стандарта [51]. Модель раскладывает риск на частоту событий потерь и величину потерь. Частота событий потерь определяется частотой событий угрозы – попыток воздействия на актив – и уязвимостью, понимаемой как вероятность того, что событие угрозы перейдёт в событие потерь; величина потерь включает первичные потери организации и вторичные потери, связанные с реакцией внешних сторон. Оценки факторов задаются распределениями, а распределение годовых потерь получается статистическим моделированием методом Монте-Карло, что позволяет выражать риск не единственным числом, а интервалом с заданной доверительной вероятностью.

Для сопоставления состояний объекта до и после внедрения мер защиты применяются показатель ожидаемых годовых потерь ALE и показатель возврата инвестиций в безопасность ROSI [32]. Ожидаемые годовые потери определяются произведением ожидаемого ущерба от единичного инцидента SLE на годовую частоту его возникновения ARO. Показатель ROSI вычисляется как отношение разности между снижением ожидаемых годовых потерь в результате внедрения меры и стоимостью меры к стоимости меры, то есть ROSI = ((ALE1 – ALE2) – C) / C, где ALE1 и ALE2 – ожидаемые годовые потери до и после внедрения меры, C – стоимость меры. Величины ALE1 и ALE2 соответствуют первичному и остаточному риску, а ROSI обеспечивает количественную верификацию решения о внедрении меры.

Сопоставление рассмотренных риск-калькуляторов приведено в таблице 5.

Таблица 5 – Сопоставление риск-калькуляторов и моделей количественной оценки риска

Средство	Что оценивает	Результат	Роль в проактивном управлении риском
CVSS 3.1	Тяжесть уязвимости по базовым, временным и средовым метрикам	Балл от 0 до 10	Характеристика условий компрометации
CVSS 4.0	Тяжесть уязвимости с раздельным учётом воздействия на уязвимую и последующие системы	Балл от 0 до 10	Характеристика условий компрометации и распространения последствий
EPSS	Вероятность эксплуатации уязвимости в течение 30 дней	Вероятность от 0 до 1	Вероятностная составляющая оценки
FAIR	Частоту событий потерь и величину потерь	Распределение годовых потерь	Расчёт первичного и остаточного риска
ALE, ROSI	Ожидаемые годовые потери и возврат инвестиций в меру защиты	Денежная величина, относительный показатель	Количественная верификация мер защиты

Из таблицы 5 следует, что рассмотренные средства дополняют друг друга и в совокупности покрывают последовательность проактивного управления риском: CVSS и EPSS характеризуют условия и правдоподобие компрометации, FAIR связывает их с частотой и величиной потерь в форме первичного и остаточного

риска, ALE и ROSI обеспечивают количественную верификацию мер защиты. Применение этой последовательности к инфраструктуре контейнеризации требует сопряжения метрик риск-калькуляторов с недостатками конфигурации кластера и сценариями их эксплуатации, что и определяет направление дальнейшего исследования.

1.6 Выявление противоречий и постановка задач работы

Выполненный анализ позволяет выявить противоречия, определяющие содержание работы. Каждое из них формулируется как расхождение между существующим состоянием информационного, методического или инструментального обеспечения и необходимостью его совершенствования для проактивного управления рисками нарушения информационной безопасности инфраструктуры контейнеризации.

Первое противоречие связано с информационным обеспечением. Сведения, необходимые для риск-анализа кластера, распределены между реестрами уязвимостей, банком данных угроз безопасности информации ФСТЭК России, перечнем CWE, профилями NIST SP 800-190 и CIS Kubernetes Benchmark и матрицей MITRE ATT&CK for Containers (подразделы 1.3 и 1.5). Для проактивного риск-анализа они должны быть сведены в единую структуру, в которой недостаток конфигурации связан с шаблоном атаки, техникой эксплуатации и наступающим ущербом, а рабочие нагрузки кластера описаны признаками, пригодными для машинной обработки. Такое сведение согласуется с принятым в отечественной научной школе подходом к формализации знаний и данных о кибератаках и уязвимостях [52].

Второе противоречие связано с методиками риск-анализа. Риск-калькуляторы CVSS и EPSS оценивают отдельную уязвимость, а средства контроля защищённости выражают результат оценкой соответствия (подразделы 1.4 и 1.5), тогда как проактивная оценка риска кластера требует учёта контекста кластера – уровня привилегий пода, пересекаемой границы доверия, доступности плоскости управления – и сочетания недостатков в сценариях компрометации. Представление

сценариев путями по графу состояний инфраструктуры развивает известные подходы к построению и анализу графов атак [33-34], в том числе вероятностные [35], а расчёт первичного риска сценария опирается на факторную модель FAIR.

Третье противоречие связано с методиками управления рисками. Меры защиты, установленные нормативными документами и профилями безопасности (подраздел 1.3), выбираются по перечню несоответствий, тогда как проактивное регулирование риска требует моделирования мер, их классификации по масштабности и профильности и расчёта остаточного риска для конкретных сценариев компрометации.

Четвёртое противоречие связано со средствами автоматизации. Существующие средства обеспечивают сбор сведений о состоянии кластера (подраздел 1.4), тогда как оценка эффективности предлагаемых технических решений требует автоматизированного выполнения полного цикла проактивного управления риском – от идентификации сценария атаки до количественной верификации эффективности выбранных мер по показателям ALE и ROSI.

Каждому противоречию ставится в соответствие задача работы, решение которой составляет содержание одной из последующих глав. Соответствие противоречий, задач и глав приведено в таблице 6.

Таблица 6 – Соответствие противоречий, задач и глав работы

Противоречие	Задача	Глава
Между существующим информационным обеспечением и необходимостью его совершенствования для проактивного риск-анализа	Создание информационного обеспечения проактивного риск-анализа	Глава 2
Между существующими методиками риск-анализа и необходимостью учёта проактивных принципов оценки риска	Создание аналитики проактивной оценки риска	Глава 3
Между существующими методиками управления рисками и необходимостью проактивного регулирования риска	Создание аналитики проактивного регулирования риска	Глава 4
Между имеющимися средствами автоматизации и необходимостью оценки эффективности предлагаемых решений	Формирование средств автоматизации и оценка эффективности мер защиты	Глава 5

Цель работы – повышение защищённости автоматизированных информационных систем за счёт разработки интеллектуальной системы оценки и регулирования киберрисков инфраструктуры контейнеризации Kubernetes в условиях компрометации контейнерных приложений – достигается последовательным решением перечисленных задач: созданное во второй главе информационное обеспечение служит входом аналитического обеспечения оценки рисков третьей главы, результаты оценки первичного риска – входом аналитического обеспечения регулирования рисков четвёртой главы, а автоматизация в пятой главе замыкает цикл количественной верификацией эффективности мер защиты.

Таким образом, выполненное в настоящей главе исследование аналогов позволило получить следующие результаты:

- установлено, что величина ущерба от компрометации рабочей нагрузки кластера Kubernetes определяется множеством активов, достижимых при её использовании, а состояние конфигурации, задающее такую достижимость, известно до реализации атаки, что делает инфраструктуру контейнеризации объектом проактивного риск-анализа;

- по данным отраслевых исследований за 2022–2025 годы установлено устойчивое преобладание недостатков конфигурации над уязвимостями образов в качестве причины инцидентов безопасности контейнерных сред и систематическое превышение необходимого объёма полномочий рабочих нагрузок;

- установлено соответствие между мерами защиты информации, предусмотренными нормативными документами ФСТЭК России и национальными стандартами, и параметрами конфигурации кластера, а профили NIST SP 800-190 и CIS Kubernetes Benchmark определены как источник перечня недостатков конфигурации, подлежащих учёту;

- выполнен сравнительный анализ средств контроля защищённости kube-bench, Kubescape, Trivy и Falco, показавший, что они являются источником первичных данных о состоянии кластера и выражают результат оценкой соответствия и перечнем находок с качественной градацией критичности;

- исследованы риск-калькуляторы CVSS 3.1, CVSS 4.0 и EPSS, факторная модель FAIR и показатели ALE и ROSI, которые в совокупности покрывают последовательность проактивного управления риском от оценки условий компрометации до количественной верификации мер защиты;

- выявлены четыре противоречия и поставлены четыре задачи работы, каждой из которых соответствует одна из последующих глав.

Существенным итогом исследования аналогов является выбор единицы риск-анализа. Поскольку величина ущерба определяется множеством активов, достижимых при компрометации конкретной рабочей нагрузки, а вероятность компрометации – параметрами её изоляции и полномочиями её сервисного аккаунта, риск в настоящей работе оценивается применительно к рабочей нагрузке кластера, а не к образу контейнера и не к кластеру в целом. Такой выбор согласуется с формой первичных данных, получаемых средствами контроля защищённости, которые описывают состояние отдельных объектов кластера, и вместе с тем позволяет перейти от этих данных к мере риска сценария, объединяющего несколько объектов. Он же определяет и форму представления результатов оценки: риск-ландшафт кластера строится как совокупность мер риска рабочих нагрузок и сценариев их компрометации, что позволяет сопоставлять между собой как отдельные нагрузки, так и состояния кластера до и после внедрения мер защиты. Существенно также, что все исходные данные для такой оценки – манифесты развёртывания, привязки ролей, параметры компонентов плоскости управления и узлов – доступны до реализации атаки, что и обеспечивает проактивный характер разрабатываемого обеспечения.

Выявленные противоречия связаны между собой последовательно: без единой структуры сведений о недостатках конфигурации невозможно сопряжение метрик риск-калькуляторов с состоянием кластера, без количественной оценки первичного риска – обоснованный выбор мер защиты, а без расчёта остаточного риска – верификация эффективности мер по показателям ALE и ROSI. Поэтому задачи работы решаются в порядке, совпадающем с порядком шагов проактивного

управления риском, и результат каждой задачи служит исходными данными для последующей.

Проведённый анализ определяет и исходные данные для последующих глав. Во второй главе в качестве источников сведений о недостатках конфигурации используются набор проверок CIS Kubernetes Benchmark, руководство NIST SP 800-190 и стандарты безопасности рабочих нагрузок, в качестве источников сведений о способах их эксплуатации – матрица MITRE ATT&CK for Containers, а в качестве эмпирического материала – манифесты рабочих нагрузок из открытых репозиториев. В третьей главе метрики CVSS 4.0 и факторы модели FAIR служат основой расчёта первичного риска сценариев компрометации. В четвёртой главе меры защиты, установленные нормативными документами и профилями безопасности, рассматриваются как множество вариантов регулирования, оцениваемых величиной остаточного риска. В пятой главе результаты работы средств контроля защищённости кластера используются как входные данные интеллектуальной системы, а показатели ALE и ROSI – как критерии эффективности мер защиты.

Полученные результаты обосновывают постановку задач исследования и определяют содержание второй – пятой глав выпускной квалификационной работы. Вклад решения каждой задачи в достижение цели работы оценивается единообразно – величиной снижения риска нарушения информационной безопасности инфраструктуры контейнеризации от первичного к остаточному значению, что обеспечивает сопоставимость результатов всех последующих глав и позволяет количественно обосновать повышение защищённости автоматизированных информационных систем, достигаемое применением разрабатываемой интеллектуальной системы.

СПИСОК ЛИТЕРАТУРЫ

1 Kubernetes Documentation: официальная документация системы оркестрации контейнерных приложений. – Электрон. дан. – Режим доступа: https://kubernetes.io/docs/. – Текст: электронный.

2 State of Kubernetes Security Report: ежегодный аналитический отчёт компании Red Hat. – Электрон. дан. – Режим доступа: https://www.redhat.com/en/resources/state-kubernetes-security-report. – Текст: электронный.

3 Cloud-Native Security and Usage Report: ежегодный аналитический отчёт компании Sysdig. – Электрон. дан. – Режим доступа: https://sysdig.com/. – Текст: электронный.

4 CNCF Annual Survey: ежегодное исследование фонда Cloud Native Computing Foundation. – Электрон. дан. – Режим доступа: https://www.cncf.io/reports/. – Текст: электронный.

5 Data Breach Investigations Report: ежегодный аналитический отчёт компании Verizon. – Электрон. дан. – Режим доступа: https://www.verizon.com/business/resources/reports/dbir/. – Текст: электронный.

6 Утечки данных в России и мире: аналитический отчёт экспертно-аналитического центра InfoWatch. – Электрон. дан. – Режим доступа: https://www.infowatch.ru/analytics. – Текст: электронный.

7 Актуальные киберугрозы: аналитические отчёты компании Positive Technologies. – Электрон. дан. – Режим доступа: https://www.ptsecurity.com/ru-ru/research/analytics/. – Текст: электронный.

8 Банк данных угроз безопасности информации ФСТЭК России. – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/threat. – Текст: электронный.

9 Common Vulnerabilities and Exposures (CVE). – Электрон. дан. – Режим доступа: https://www.cve.org/. – Текст: электронный.

10 National Vulnerability Database (NVD). – Электрон. дан. – Режим доступа: https://nvd.nist.gov/. – Текст: электронный.

11 Common Vulnerability Scoring System v3.1: Specification Document. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v3.1/specification-document. – Текст: электронный.

12 Common Vulnerability Scoring System v4.0: Specification Document. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v4.0/specification-document. – Текст: электронный.

13 Exploit Prediction Scoring System (EPSS). – Электрон. дан. – Режим доступа: https://www.first.org/epss/. – Текст: электронный.

14 Kubescape: средство анализа защищённости кластера Kubernetes. – Электрон. дан. – Режим доступа: https://github.com/kubescape/kubescape. – Текст: электронный.

15 kube-bench: средство проверки конфигурации кластера на соответствие CIS Kubernetes Benchmark. – Электрон. дан. – Режим доступа: https://github.com/aquasecurity/kube-bench. – Текст: электронный.

16 Trivy: средство выявления уязвимостей образов контейнеров и ошибок конфигурации. – Электрон. дан. – Режим доступа: https://github.com/aquasecurity/trivy. – Текст: электронный.

17 Falco: средство обнаружения аномального поведения среды исполнения контейнеров. – Электрон. дан. – Режим доступа: https://falco.org/docs/. – Текст: электронный.

18 Freund J. Measuring and Managing Information Risk: A FAIR Approach / J. Freund, J. Jones. – Oxford: Butterworth-Heinemann, 2014. – Текст: непосредственный.

19 ГОСТ Р ИСО/МЭК 27005-2010. Информационная технология. Методы и средства обеспечения безопасности. Менеджмент риска информационной безопасности. – Москва: Стандартинформ, 2011. – Текст: непосредственный.

20 Остапенко А.Г. Краткие научно-методические рекомендации по формированию и выполнению технических заданий в области обеспечения информационной безопасности / А.Г. Остапенко, М.Е. Волкова, Д.А. Нархов, А.А. Остапенко, А.В. Заряев, Т.Ю. Мирошниченко, П.Д. Федоров // Информация и безопасность. – 2020. – Т. 23, вып. 4. – С. 551-560. – Текст: непосредственный.

21 Остапенко Г.А. Совершенствование организационно-правового обеспечения информационной безопасности предприятия: формирование риск-ландшафта сетевых атак / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Ю. Пекло // Информация и безопасность. – 2023. – Т. 26, вып. 2. – С. 203-210. – Текст: непосредственный.

22 Сердечный А.Л. Риск-анализ и прогнозирование частоты и ущербности компьютерных атак / А.Л. Сердечный, А.С. Маликова, А.Г. Остапенко, М.Е. Волкова, Д.А. Нархов, А.Н. Бартенев // Информация и безопасность. – 2021. – Т. 24, вып. 2. – С. 159-178. – Текст: непосредственный.

23 Об утверждении Требований о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах: приказ ФСТЭК России от 11 февраля 2013 г. № 17. – Электрон. дан. – Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/prikazy/prikaz-fstek-rossii-ot-11-fevralya-2013-g-n-17. – Текст: электронный.

24 Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных: приказ ФСТЭК России от 18 февраля 2013 г. № 21. – Электрон. дан. – Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/prikazy/prikaz-fstek-rossii-ot-18-fevralya-2013-g-n-21. – Текст: электронный.

25 Об утверждении Требований по обеспечению безопасности значимых объектов критической информационной инфраструктуры Российской Федерации: приказ ФСТЭК России от 25 декабря 2017 г. № 239. – Электрон. дан. – Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/prikazy/prikaz-fstek-rossii-ot-25-dekabrya-2017-g-n-239. – Текст: электронный.

26 ГОСТ Р 50922-2006. Защита информации. Основные термины и определения. – Москва: Стандартинформ, 2006. – Текст: непосредственный.

27 ГОСТ Р 56545-2015. Защита информации. Уязвимости информационных систем. Правила описания уязвимостей. – Москва: Стандартинформ, 2015. – Текст: непосредственный.

28 ГОСТ Р 56546-2015. Защита информации. Уязвимости информационных систем. Классификация уязвимостей информационных систем. – Москва: Стандартинформ, 2015. – Текст: непосредственный.

29 NIST Special Publication 800-190. Application Container Security Guide. – Электрон. дан. – Режим доступа: https://csrc.nist.gov/publications/detail/sp/800-190/final. – Текст: электронный.

30 CIS Kubernetes Benchmark: набор проверок конфигурации кластера центра интернет-безопасности. – Электрон. дан. – Режим доступа: https://www.cisecurity.org/benchmark/kubernetes. – Текст: электронный.

31 MITRE ATT&CK Containers Matrix. – Электрон. дан. – Режим доступа: https://attack.mitre.org/matrices/enterprise/containers/. – Текст: электронный.

32 Sonnenreich W. Return On Security Investment (ROSI): A Practical Quantitative Model / W. Sonnenreich, J. Albanese, B. Stout // Journal of Research and Practice in Information Technology. – 2006. – Vol. 38, № 1. – P. 45-56. – Текст: непосредственный.

33 Sheyner O. Automated Generation and Analysis of Attack Graphs / O. Sheyner, J. Haines, S. Jha, R. Lippmann, J.M. Wing // Proceedings of the IEEE Symposium on Security and Privacy. – Oakland, 2002. – P. 273-284. – Текст: непосредственный.

34 Ou X. MulVAL: A Logic-based Network Security Analyzer / X. Ou, S. Govindavajhala, A.W. Appel // Proceedings of the 14th USENIX Security Symposium. – Baltimore, 2005. – P. 113-128. – Текст: непосредственный.

35 Poolsappasit N. Dynamic Security Risk Management Using Bayesian Attack Graphs / N. Poolsappasit, R. Dewri, I. Ray // IEEE Transactions on Dependable and Secure Computing. – 2012. – Vol. 9, № 1. – P. 61-74. – Текст: непосредственный.

36 Sultan S. Container Security: Issues, Challenges, and the Road Ahead / S. Sultan, I. Ahmad, T. Dimitriou // IEEE Access. – 2019. – Vol. 7. – P. 52976-52996. – Текст: непосредственный.

37 etcd: распределённое хранилище состояния кластера. – Электрон. дан. – Режим доступа: https://etcd.io/docs/. – Текст: электронный.

38 containerd: среда исполнения контейнеров. – Электрон. дан. – Режим доступа: https://containerd.io/docs/. – Текст: электронный.

39 Using RBAC Authorization: механизм управления доступом на основе ролей в Kubernetes. – Электрон. дан. – Режим доступа: https://kubernetes.io/docs/reference/access-authn-authz/rbac/. – Текст: электронный.

40 Rahman A. Security Misconfigurations in Open Source Kubernetes Manifests: An Empirical Study / A. Rahman, S.I. Shamim, D.B. Bose, R. Pandita // ACM Transactions on Software Engineering and Methodology. – 2023. – Vol. 32, № 4. – P. 1-36. – Текст: непосредственный.

41 Методика оценки угроз безопасности информации: методический документ ФСТЭК России, утверждён 5 февраля 2021 г. – Электрон. дан. – Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/spetsialnye-normativnye-dokumenty/metodicheskij-dokument-ot-5-fevralya-2021-g. – Текст: электронный.

42 ГОСТ Р 56938-2016. Защита информации. Защита информации при использовании технологий виртуализации. Общие положения. – Москва: Стандартинформ, 2016. – Текст: непосредственный.

43 ГОСТ Р ИСО 31000-2019. Менеджмент риска. Принципы и руководство. – Москва: Стандартинформ, 2020. – Текст: непосредственный.

44 ГОСТ Р 58771-2019. Менеджмент риска. Технологии оценки риска. – Москва: Стандартинформ, 2020. – Текст: непосредственный.

45 CIS Docker Benchmark: набор проверок конфигурации среды исполнения контейнеров. – Электрон. дан. – Режим доступа: https://www.cisecurity.org/benchmark/docker. – Текст: электронный.

46 Kubernetes Hardening Guide: руководство Агентства национальной безопасности и Агентства по кибербезопасности и защите инфраструктуры США. – Электрон. дан. – Режим доступа: https://www.cisa.gov/resources-tools/resources/kubernetes-hardening-guide. – Текст: электронный.

47 OWASP Kubernetes Top Ten: перечень наиболее значимых рисков безопасности инфраструктуры Kubernetes. – Электрон. дан. – Режим доступа: https://owasp.org/www-project-kubernetes-top-ten/. – Текст: электронный.

48 Pod Security Standards: стандарты безопасности рабочих нагрузок Kubernetes. – Электрон. дан. – Режим доступа: https://kubernetes.io/docs/concepts/security/pod-security-standards/. – Текст: электронный.

49 Admission Controllers Reference: контроллеры допуска рабочих нагрузок в Kubernetes. – Электрон. дан. – Режим доступа: https://kubernetes.io/docs/reference/access-authn-authz/admission-controllers/. – Текст: электронный.

50 Common Weakness Enumeration (CWE). – Электрон. дан. – Режим доступа: https://cwe.mitre.org/. – Текст: электронный.

51 The Open Group Standard. Risk Taxonomy (O-RT), Version 3.0.1. – Электрон. дан. – Режим доступа: https://publications.opengroup.org/. – Текст: электронный.

52 Остапенко Г.А. Формализация знаний и данных кибератак и уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Покудин // Информация и безопасность. – 2024. – Т. 27, вып. 2. – С. 231-238. – Текст: непосредственный.